

AmasCar Gitleaks 機密掃描報告

全專案 Git 歷史機密掃描

掃描日期：2026-08-14 掃描工具：Gitleaks 掃描範圍：19 條分支（本機 6 / 遠端 19） / 551 個 commit 遠端同步：2026-08-14 16:01:15

19
掃描分支數（去重）

551
檢查 commit 數

1
潛在洩漏風險（finding）

Medium-High
整體風險等級

一、執行摘要

本次針對本機可見全部 19 條分支（本機 6 / 遠端 19，其中 13 條僅存在遠端：`demo/#4924`、`develop`、`feat/admin_usage`、`feat/car_management`、`feat/fuel_record`、`feat/mileage_validation_and_etag_updates/#4924`、`feat/permissions_add_mainten_mail/#4924`、`feat/reserve`、`feat/system_setup_and_login`、`feat/user_guide`、`hotfix/image-upload/#4910`、`release2.1.0`、`test/mileage_etag_permissions_add_unit_test/#4924`）、551 個 commit 進行機密掃描，共發現 1 筆 finding：`config/google_api_secret.json`（GCP 服務帳戶金鑰）。該檔案已於 2026-04-20 從現行程式碼移除，目前分支（`feat/add_git_leaks`）與 `main` 皆未追蹤此檔案，但引入該金鑰的 commit（59448f32）目前仍存在於 `remotes/origin/feat/reserve` 遠端分支的歷史中，代表任何有 repo 讀取權限者仍可從歷史還原出這把金鑰。此結果與 2026-08-10 掃描一致，撤銷狀態仍待人工確認；後續需確認此金鑰是否已在 GCP Console 撤銷 / 輪替，並評估是否要改寫該分支歷史徹底清除。

二、風險明細與資安分析

Finding 1（Medium-High）：`config/google_api_secret.json`

項目	內容
洩漏內容	RuleID: <code>private-key</code> / entropy: <code>6.001951</code> / 檔案: <code>config/google_api_secret.json</code> ，行號 5（內容為 GCP 服務帳戶金鑰，type: <code>service_account</code> ，project_id: <code>rails-project-308807</code> ，服務帳戶: <code>amas-reserve@rails-project-308807.iam.gserviceaccount.com</code> ）
進入歷史	日期: 2026-04-16 commit 碼: <code>59448f32</code> 作者: <code>kl990899 <kl990899@amastek.com></code> 描述: <code>feat: 借還、google calendaer、mail notify maintain</code>
移除時間	日期: 2026-04-20 commit 碼: <code>0da8d2d7</code> 作者: <code>kl990899 <kl990899@amastek.com></code> 描述: <code>fix: 優化格式</code>
目前風險	存在於以下分支: <code>remotes/origin/feat/reserve</code> ；是否已確認在遠端: 是（本機看得到的 <code>remotes/origin/*</code> 分支中包含引入此金鑰的 commit，此結果僅反映本機上次同步遠端的狀態即 2026-08-14 16:01:15，不保證是遠端當下即時狀態；分支名稱以本機快照為準，若該分支在 GitHub 上已刪除，遠端曝露判定應下修）
建議處理做法	1. 立即層面: 這是 GCP 服務帳戶金鑰（project_id: <code>rails-project-308807</code> ，服務帳戶: <code>amas-reserve@rails-project-308807.iam.gserviceaccount.com</code> ），建議至 GCP Console → 「IAM 與管理」→ 「服務帳戶」找到該帳戶，撤銷 / 刪除對應的金鑰 ID，並視情況輪替為新金鑰 2. git 歷史層面: 該 commit 目前仍存在於 <code>remotes/origin/feat/reserve</code> 的歷史中，如需徹底清除需使用 <code>git filter-repo</code> 或 BFG 改寫該分支歷史；這屬於改寫歷史的操作，需要強制推送、且所有協作者要重新 clone 或重建本機分支，影響範圍大，本報告僅提出建議，實際是否執行、由誰執行需使用者自行決定與操作

評估維度	客觀依據 / 資安標準	本案實測狀況	對風險等級的影響
洩漏類型（CWE）	CWE-798（Use of Hard-coded Credentials） / CWE-321（Use of Hard-coded Cryptographic Key）	RuleID: <code>private-key</code> ，內容確認為 RSA private key 本體	基礎分類偏高危（憑證 / 金鑰直接寫入版控）
可利用性（Exploitability）	CVSS: Attack Vector	<code>confirmed_on_remote = true</code> ，存在於 <code>remotes/origin/feat/reserve</code>	Attack Vector: Network，任何有此 repo 讀取權限者皆可直接從歷史取得，可利用性「高」
防護性 / 存續性（Exposure）	CVSS: Scope / Remediation Level	<code>tracked_now = false</code> ，2026-04-20 已從現行程式碼移除	非直接曝露於當前最新程式碼，但歷史未清理，防護性「部分改善」

資訊熵 (Entropy)	Gitleaks Rule Detection	entropy : 6.001951	偏高熵，且內容經人工複查確認為真實私鑰格式，非誤判或範例字串
---------------	-------------------------	--------------------	--------------------------------

綜合評定：**Medium–High**。依「已同步遠端 × 已移除僅存於歷史」對應到矩陣中的 Medium–High 區間。實際風險是否等同 High，取決於這把金鑰是否已在 GCP Console 撤銷 / 輪替——這一點無法從 git 歷史掃描判斷，需要人工確認；已撤銷則可降為 Low（僅剩 git 歷史規範問題），未撤銷則等同 High。